
Z.AI SECURITY AUDIT · v0.6.4 · GRADE: GREEN

Bitcoin Easy Signer

The conversion report: the release that published itself through its own automated gates, closing the prior audit's single open finding. No breach found on the delta, the money path unchanged across three audited versions, and the grade rules applied exactly as locked. Yellow, remediated, Prepared by Z.ai (GLM-5.3, via ZCode) · Red, Green — the progression, documented. Blue, Amber in one wave and the White referee · 2 October 2026

Contents

Document Control

The Grade: Green — the Conversion, Demonstrated

The Panel

Honest Ledger — What Remains Open

What This Audit Did Not Do

Appendix — Findings Ledger (BESA-45...53)

1

2

2

3

3

4

Document Control

Field	Detail
Report title	Z.ai Security Audit — Bitcoin Easy Signer v0.6.4 — Conversion Report
Report identifier	DOC ZAI-BESA-064 · designed edition of the report published at releases/AUDIT-ZAI-0.6.4.md
Subject	Bitcoin Easy Signer v0.6.4 — the conversion release closing the v0.6.3 Yellow's single open Medium finding
Version examined	Tag v0.6.4 · commit 35cdedb150cef6d047c39537324faf1321be3c8d · published 2 October 2026, 13:01:38 UTC, by the automated publish workflow itself
Auditor	Z.ai (GLM-5.3, via ZCode) — Color Team conversion re-check: Red, Blue, and Amber dispatched simultaneously; the White referee verified every load-bearing claim and ruled
Grade	Green — the Yellow-to-Green conversion defined by the prior referee is demonstrated by execution: the automated publish gates ran, in order, and published the exact tested bytes
Classification	Public — released to the project repository

Findings ledger continues the series: BESA-01...25 (v0.6.2 cycle, all actionable fixed), BESA-26...44 (v0.6.3 cycle), BESA-45...53 (this cycle).

The Grade: Green — the Conversion, Demonstrated

The single finding that held v0.6.3 at Yellow was that its publication bypassed the project's own machine-enforced release gates. The locked conversion criterion was execution, not intention: one release actually published through the automated path, end to end. v0.6.4 is that release.

GREEN GRADE, CONVERSION EARNED	0 CRITICAL OR HIGH, BOTH CYCLES	261 TESTS PASSING, NONE DELETED	2 FAIL-CLOSED GATE REHEARSALS
--	---	---	---

- A non-publishing candidate run (37008418851) built and notarized the release from commit 35cdedb and produced its checksums.
- Eight minutes later, a publishing run (37009396873, same commit) machine-verified the candidate — same workflow, same commit, manifest checked line by line, artifact digests re-verified — then executed “Verify downloaded release bytes” (checksums: all OK) and the tag guard BEFORE creating the release at 13:01:38 UTC. The release author is github-actions[bot], not a human.
- The published files are byte-identical to the tested candidate's checksums, verified independently from three directions: candidate artifact, published asset, local download.
- The gates are demonstrably real: two earlier rehearsal attempts failed — fail-closed, creating nothing — before the clean pair.

The remediation order's optional fallback (a dated owner-acceptance note for manual publication) was superseded by something stronger: the release process now prohibits manual publication outright — “if the workflow is unavailable, wait to publish.” The referee records the residual honestly (BESA-45): policy on paper cannot machine-prevent a credentialed owner, which is precisely why the grade rests on demonstrated execution, not on the policy.

The Panel

Conversion re-check: three specialists in one simultaneous wave plus the referee. Orange's and Copper's v0.6.3 verdicts carry over by identity — the code they audited is byte-identical at this release (the conversion changed process and tests, not the application).

	Agent	Verdict	Report
	Red	No breach on the delta	The change surface touches no application code — the money path is byte-identical across v0.6.2, v0.6.3, and v0.6.4, provable by blob hash. Every attempt to bypass the new candidate-to-publish linkage (wrong-commit promotion, byte substitution, unsigned publication, tag races) failed closed. Two informational notes.
	Blue	Defenses hold	Every remediation item met and mutation-verified: each new guard was surgically reverted in a scratch clone and its test went red. The three refusal-branch pins, the returned-transaction-ID pin, and the SBOM hash all genuinely bite. Suite grew 253 → 261, zero deletions.

	Agent	Verdict	Report
	Amber	Chain holds	The grade item, closed with primary evidence: the publishing run executed digest verification twice and the tag guard before creating the release, inside its own window, with the candidate machine-linked and bytes provably identical end to end. Record-keeping compliant; SBOM now carries the vendored cryptography wheel's hash.
	White	Green — earned, not given	Re-derived every load-bearing claim personally, ran its own mutation test, corrected three citation drifts, merged the ledger (BESA-45...53: two Low, seven Info), applied the locked rubric clause by clause, and ruled. Publication approved.

Honest Ledger — What Remains Open

Green does not mean nothing left. Carried forward, explicitly not claimed fixed:

- BESA-26: the physical device-swap window, bounded to denial-of-service — no forged signature can survive verification.
- BESA-29: the hardware helper's entitlement and extraction surface; BESA-30: the vendored USB binary's repo-circular trust anchors; BESA-32: the tag-check timing window.
- New this cycle — BESA-45 (Low): no dated personal owner sign-off on the manual-publication prohibition; BESA-46 (Low): the source-archive allowlist completeness note.
- BESA-47...53 (Info): workflow input-validation style, test brittleness notes, the discarded rebuild not bit-compared, the release-timestamp quirk, and bookkeeping corrections.
- The vendored cryptography patch remains unmerged upstream; the re-audit obligation at every future library bump stands.

What This Audit Did Not Do

- No panel agent attached hardware; the owner's prior physical acceptance covers unchanged app behavior, and this release changed none.
- The automated publish path has now been demonstrated in execution exactly once — one clean pair of runs.
- The publishing run's own rebuilt artifacts were discarded without bit-comparison to the candidate (published bytes are provably the candidate's; notarized builds are not reproducible).
- “No finding” means “none found within this coverage,” not “none exist.”

Appendix — Findings Ledger (BESA-45...53)

ID	Severity	Finding
BESA-45	Low	No dated owner-acceptance sign-off on the manual-publication prohibition; paper cannot machine-prevent a credentialed owner (the grade rests on demonstrated execution)
BESA-46	Low	Source-archive completeness check now allowlist-based; future root documents could be silently excluded — intentional and documented
BESA-47	Info	candidate_run_id interpolated directly in one workflow guard while other sites use the env form; no privilege boundary crossed
BESA-48	Info	Source-archive test asserts script text rather than behavior; false-red-only risk (downgraded from Low by the referee)
BESA-49	Info	Packaged-archive self-check lacks the skip-refusal wrapper the in-repo suite step has
BESA-50	Info	SBOM-to-wheel and wheel-to-lock pinned in separate tests; the composite chain is closed transitively
BESA-51	Info	Publishing run's rebuilt artifacts discarded without bit-comparison to the candidate
BESA-52	Info	GitHub release created_at mirrors the commit date, not the publication instant; auditors should use asset timestamps and job logs
BESA-53	Info	Workflow-delta bookkeeping discrepancy across cycle records; true cycle delta +99/−12 lines

Audit performed 2 October 2026 by Z.ai on the public repository and published artifacts only, under grade rules locked before each cycle began and applied as written. The progression Yellow → remediation → Green is documented across this report and its two predecessors, each carrying the grade its evidence supported on the day. No wallet material, addresses, or transaction identifiers appear in this report. An audit is not a certification of safety; it is dated evidence about one revision, and its coverage limits are stated above.